

PicoCTF 2022 – RPS

RPS

Binary Exploitation

Medium

200 pts

by Will Hong

Here's a program that plays rock, paper, scissors against you. I hear something good happens if you win 5 times in a row.

The program's source code with the flag redacted can be downloaded [here](#) [↗].

This challenge requires us to win 5 games of Rock-Paper-Scissors in the app

PicoCTF 2022 – RPS

Programming Logic Flaw

```
if (strstr(player_turn, loses[computer_turn]))  
    puts("You win! Play again?");  
return true;
```

When we download the C source code for the program, we see that there is a login flaw in the code

PicoCTF 2022 – RPS

Programming Logic Flaw

```
if (strstr(player_turn, loses[computer_turn]))  
    puts("You win! Play again?");  
return true;
```

The program runs the `strstr` function with the player input (`player_turn`) and the hands the computer's hand loses to (`loses[computer_turn]`)

PicoCTF 2022 – RPS

C Strstr Function

Definition and Usage

The `strstr()` function returns a pointer to the position of the first occurrence of a string in another string.

The `strstr` function searches for the first occurrence of a target string (the needle) in a second string (the haystack)

PicoCTF 2022 – RPS

The Exploit

Example Game Round

- 1) The computer plays rock
- 2) Rock loses to paper
- 3) The program checks player input for paper
- 4) The player always wins if they input "rockpaperscissors"

Because the user types in their input instead of selecting one of three options, the player can type in all three options at once, and win every time

PicoCTF 2022 – RPS

The Exploit

```
Please make your selection (rock/paper/scissors):  
rockpaperscissors
```

```
You played: rockpaperscissors  
The computer played: paper  
You win! Play again?
```

When we interact with the program on the server,
we see that this exploit works